SECURITY

Secrets Management with Vault Visual Guide

Dynamic secrets, leases, rotation — stop hardcoding credentials forever.

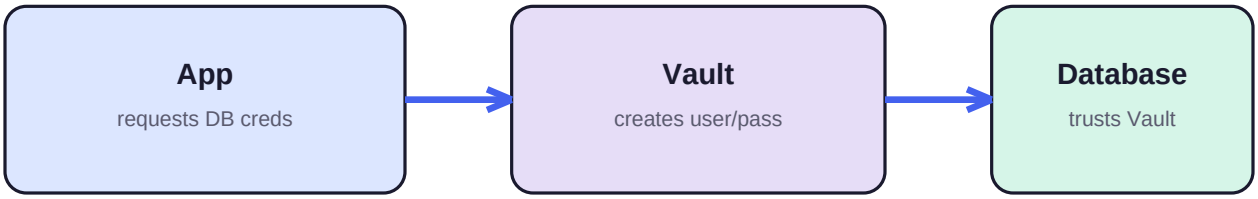
ANIMATED WALKTHROUGH

Step through pages to play the animation

STEP 1/6

Dynamic Secrets

Credentials minted on demand, dead on arrival's schedule.



Each app instance gets UNIQUE, short-lived credentials. A leaked password is useless within minutes — and you know exactly which lease leaked.

STEP 2/6

Leases & Renewal

Every secret has a countdown.

Apps renew leases while healthy; dead apps' secrets auto-expire. Revocation is instant and centralized — one call kills every copy.

STEP 3/6

Automatic Rotation

Secrets change themselves on a schedule.

- Static secrets (API keys, passwords) rotate on a timer — weekly, not yearly.
- Rotation writes the new value to BOTH Vault and the target system atomically.
- Apps always read the current value from Vault — never cache secrets in config.
- Break-glass: rotate immediately on any suspected exposure, then investigate.

STEP 4/6

Auth Methods

How callers prove they deserve secrets.

Machines authenticate with platform identity (service accounts), humans via SSO. Long-lived tokens are the last resort, tightly scoped.

STEP 5/6

Policies: Least Privilege for Secrets

Every identity sees only what it needs.

```
path "secret/data/payments/*" { capabilities = ["read"] }
```

policy snippet

- Bind policies to auth identity: the payments service reads payments secrets only.
- Deny by default; no wildcards in production policies.
- Audit every read — anomalous secret access is an early breach signal.

STEP 6/6

Seal, HA & Backup

Vault guards the guards — operate it carefully.

- Unseal requires multiple key shares (Shamir) — no single operator opens Vault alone.
- Run HA (Raft) across zones; back up encrypted snapshots offsite regularly.
- Monitor: seal status, lease counts, audit device health — Vault down means deploys stall.
- Disaster recovery: rehearse restore from snapshot before you need it.

STEP ✓/✓

Key Takeaways

Vault Secrets — Remember

- Dynamic secrets: unique, short-lived credentials per consumer — leaks self-heal.
- Leases give every secret a TTL; renewal for the living, revocation for the dead.
- Rotate static secrets automatically; apps always read live from Vault.
- Authenticate machines with platform identity, humans with SSO.
- Policies enforce least privilege; audit every secret read.
- Shamir unseal, HA, and rehearsed backups keep Vault itself resilient.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev